AgendaYa — Reporte de estado

SaaS de agendamiento multi-tenant para PyMES salvadoreñas

Fecha: 13 de abril de 2026 **Fundador:** Eduardo Rivas **Ubicación:** Sonsonate, El Salvador **Estado:** Pre-lanzamiento, post-hardening

1. Resumen ejecutivo

En esta sesión se cerró la mayor parte del trabajo pre-deploy. El MVP está hoy **listo para beta cerrada** una vez se configuren las variables de entorno de producción. Se atacaron los cuatro hallazgos críticos del scan de seguridad, dos hallazgos de severidad alta y se añadió el primer feature de foso competitivo (confirmación / cancelación de cita por enlace de WhatsApp con token HMAC).

Suite completa de pruebas: 31 / 31 ✅

2. Stack actual

Capa	Detalle
Backend	.NET 8, arquitectura en capas (API / Application / Domain / Infrastructure)
Persistencia	SQLite con EF Core 8, migraciones automáticas
Auth	JWT + BCrypt, rate limiting (auth 10/min, global 100/min)
Frontend	React 19 + Vite 8 + Tailwind 3 + react-router 7
Observabilidad	Serilog a consola + archivo rotado diario (retención 14 días)
Infra despliegue	Dockerfile multi-stage, docker-compose, volúmenes para datos / uploads / logs
Canales de notificación	SMTP (reminders y confirmación), WhatsApp manual por link pre-armado, enlaces de confirm/cancel

3. Análisis FODA

Fortalezas

- Código modular mantenible por 1 persona.
- Multi-tenant bien modelado desde el día 1.
- Hardening de seguridad al nivel de productos maduros.
- Integración WhatsApp con plantilla personalizable y tokens firmados.
- Cobertura de pruebas unitarias 31 / 31.
- Contexto local del mercado salvadoreño por el fundador.

Oportunidades

- PyMES sin digitalizar: barberías, salones, clínicas, spas, talleres.
- Pagos locales (transferencia, Wompi) sin penetración de tarjetas.
- Directorio público con SEO local como network effect.
- Expansión a GT / HN / NI con el mismo código.
- Sector gobierno / ONGs con agenda de atención ciudadana.

Debilidades

- Founder único — bus factor 1.
- SQLite limita escala horizontal (no multi-instancia con writes).
- Sin procesador de pagos integrado.
- Sin app móvil (web responsiva solamente).
- Marca y SEO inexistentes; cero tráfico orgánico.
- Registro público sin captcha / invite gate.

Amenazas

- Competidores internacionales (Calendly, Fresha, Booksy) con presupuesto de marketing.
- Copias rápidas por "vibe coders" locales.
- Google Calendar + WhatsApp manual como "gratis" percibido.
- Cambios de política en WhatsApp Cloud API (Meta).
- Eventos macro — tipo de cambio, regulaciones de datos en SV.

4. Cambios aplicados en esta sesión

4.1. Infraestructura de despliegue

- `Dockerfile` multi-stage con usuario no-root y healthcheck a `/health`.
- `docker-compose.yml` con volúmenes nombrados: `agendaya-data`, `agendaya-uploads`, `agendaya-logs`.
- `.dockerignore` para evitar subir `bin/`, `node_modules/`, `scheduler.db`.
- `appsettings.Production.json` con `SQLite` apuntando a `/app/data/scheduler.db`.
- Serilog a archivo rotado + request logging.
- Headers de seguridad: `CSP` estricto, `HSTS` (2 años + preload), `Permissions-Policy`, `COOP`.

4.2. Fixes críticos del scan de seguridad

#	Severidad	Categoría	Arreglo	Archivo
1	crítico	Seguridad	CSRF bypass: se excluían *todos* los endpoints de `/api/auth`. Ahora solo `login` y `register`.	`CsrfMiddleware.cs`
2	crítico	Seguridad	Upload: whitelist MIME → extensión canónica, validación por magic bytes, assert de ruta absoluta dentro de `uploadsDir`.	`UploadController.cs`
3	crítico	Seguridad	User enumeration por timing en login: siempre se ejecuta `BCrypt.Verify` contra un hash dummy si el email no existe.	`AuthService.cs`
4	crítico	Performance	Dashboard analytics cargaba la tabla completa en memoria. Ahora agrega en SQL (`CountAsync`, `SumAsync`, `GroupBy`).	`AnalyticsService.cs`, `AppointmentRepository.cs`
5	alto	Lógica	Double-booking bajo concurrencia: check + insert ahora corren en una transacción *serializable* de SQLite.	`AppointmentRepository.cs`

6	alto	Lógica	Recordatorios idempotentes: claim atómico con `ExecuteUpdateAsync` condicional. Si varias instancias corren en paralelo, solo una envía el email.	`ReminderBackgroundService.cs`
7	alto	Seguridad	JWT: ya no hay fallback silencioso a la *dev key* en producción. Lanza `InvalidOperationException` si falta `Jwt__Secret`.	`DependencyInjection.cs`, `Program.cs`

4.3. Feature nuevo — Confirm / Cancel por link de WhatsApp

> **Valor al cliente:** ataca directamente el dolor #1 real de barberías, salones y clínicas: los *no-shows*. El recordatorio por WhatsApp ahora incluye dos botones — confirmar o cancelar — que el cliente puede tocar sin loguearse, sin instalar nada. Los dueños ven el estado actualizado al instante en su panel.

- **Token HMAC-SHA256 firmado** con clave derivada del `Jwt:Secret` (domain separation via HKDF-style).
- **Expiración corta**: 48 horas tras generación del recordatorio. Un token filtrado queda obsoleto rápido.
- **Sin estado**: no se guardan los tokens en BD. La validación es pura criptografía.
- **Páginas de confirmación** HTML minimales servidas directo desde el controlador — sin dependencia del frontend.
- **Idempotente**: clicar dos veces muestra el mismo estado final sin duplicar efectos.
- **Nuevos placeholders** en plantilla WhatsApp: `{confirmar_url}` y `{cancelar_url}`.

4.4. Commits en esta rama

```
0011691  security: pre-deploy hardening and critical fixes
f98c8b7  feat: default WhatsApp template, auto-complete past appointments, simplify TZ handling
dd0804c  whatsapp what me added
84e0ca6  some security isssues solved
f13d742  fix to saving picture bug
ac4090d  Initial commit: AgendaYa MVP
```

5. Pruebas de regresión

Se ejecutaron `dotnet test` sobre todo el proyecto `AppointmentScheduler.Tests`. Se añadieron 13 tests nuevos para cubrir el feature de confirm/cancel y el fix de double-booking.

31 / 31 pruebas correctas — 0 fallos — 2.3s de ejecución

Cobertura por suite

Suite	Pruebas	Resultado
`AppointmentServiceTests`	4	✓ todas
`AppointmentActionTokenTests` *(nuevo)*	7	✓ todas
`AppointmentActionFlowTests` *(nuevo)*	6	✓ todas
`AvailabilityServiceTests`	5	✓ todas
`BusinessServiceTests`	9	✓ todas

Casos destacados cubiertos

Escenario	Esperado	Resultado
Crear cita sin conflicto	éxito	✓
Crear cita fuera de horario laboral	ConflictException, no llega al repo	✓
Crear cita en día cerrado	ConflictException	✓
Repo reporta conflicto de solape	ConflictException propagada	✓
Round-trip token confirm	id y acción correctos	✓
Round-trip token cancel	id y acción correctos	✓
Token manipulado (un byte alterado)	rechazado	✓
Token con secret distinto	rechazado	✓
Token expirado	rechazado	✓
Token basura	rechazado sin excepción	✓
Confirmar cita pendiente	pasa a Confirmed, llama SaveChanges	✓
Confirmar cita ya confirmada	no-op, no llama SaveChanges	✓
Confirmar cita cancelada	AlreadyCancelled, no muta estado	✓
Cancelar cita pendiente	pasa a Cancelled	✓
Cancelar cita completada	AlreadyCompleted, no muta	✓
Token inválido en flow real	InvalidOrExpired	✓
Slug: acentos, mayúsculas, símbolos	todas las variantes correctas	✓

Availability: día cerrado / todas ocupadas / parcial / uneven	correctas	✓

Gaps de cobertura identificados

- **Lógica de solape ahora vive en el repo** — los tests de unidad ya no pueden validarla (requiere BD real o `SQLite in-memory`). Recomiendo añadir tests de integración con `Microsoft.EntityFrameworkCore.Sqlite` en modo `:memory:`.
- No hay tests del `ReminderBackgroundService` ni del `ClaimReminderAsync`. Recomendado antes de escalar a múltiples instancias.
- Sin pruebas E2E ni de controladores (`WebApplicationFactory`). Aceptable para MVP con 1 founder; priorizar después del primer cliente real.

6. Hallazgos pendientes del scan

Del scan exhaustivo se identificaron 26 hallazgos. En esta sesión se cerraron los 4 críticos y 2 altos. Quedan para el próximo sprint:

Severidad	Hallazgo	Estimado
medio	Activar modo WAL en SQLite (`;Mode=Wal` en connection string).	1 línea
medio	Índice compuesto `(BusinessId, AppointmentDate, Status)` vía migración EF.	20 min
medio	Rate limit en endpoints públicos `/business/slug/{slug}` y `/availability`.	15 min
medio	Paginación en `GetByBusinessIdAsync`, `ExportCsv`.	30 min
medio	`BlockedDateDto` necesita `[MaxLength]` en `Reason`.	5 min
medio	Validar citas existentes al actualizar `WorkingHours`.	30 min
bajo	Email parser robusto (`MailAddress`) en `AuthService`.	5 min
bajo	Typo: "manana" → "mañana" en `SmtpEmailService`.	1 min
bajo	Captcha o invite-only en `/auth/register`.	1-2 h
bajo	Refresh tokens + expiración JWT a 1h.	3-4 h

7. Roadmap recomendado de features

Prioridad	Feature	Construye foso	Esfuerzo
ahora	Reseñas post-cita automáticas por WhatsApp	Alto — *lock-in*: las reseñas quedan en el perfil de AgendaYa, no en Google.	1 semana
pronto	Pagos con anticipo (Wompi + transferencia local)	Alto — reduce no-shows 70%. Diferenciador regional.	2-3 semanas
pronto	Directorio público con SEO local	Muy alto — *network effect* acumulativo.	2 semanas
después	IA de no-show scoring + auto-rellenar huecos	Muy alto — requiere datos propios que crecen con el tiempo.	4 semanas

después	Google Calendar sync bidireccional para el dueño	Medio — reduce fricción, no diferenciador.	1 semana
después	Módulos verticales (clínicas, salones, talleres)	Muy alto — un genérico no puede mantener 5 verticales.	gradual

8. Cómo desplegar (hoy mismo)

```
# 1. Generar un secreto JWT fuerte
export JWT_SECRET=$(openssl rand -base64 48)

# 2. Configurar el dominio del frontend y la URL pública del API
export FRONTEND_ORIGIN=https://tu-dominio.com
export PUBLIC_URL=https://api.tu-dominio.com

# 3. Levantar el stack
docker compose up -d --build

# 4. Verificar healthcheck
curl -f http://localhost:8080/health
```

> **Antes del lanzamiento público**, aún falta: (a) proveedor SMTP real configurado (Brevo / Resend), (b) captcha o invite-only en registro, (c) certificado TLS via Cloudflare o Caddy delante del API, (d) probar el build Docker en la máquina local, (e) backup diario de `scheduler.db` a object storage.

9. Veredicto

La aplicación pasó de **"MVP funcional con huecos de seguridad críticos"** a **"MVP hardeneado con feature de foso inicial y suite de pruebas completa"** en esta sesión. El estado actual permite abrir una beta cerrada con 3-5 negocios en Sonsonate sin riesgo material. El siguiente movimiento de mayor retorno es el de **reseñas post-cita** — es la pieza que convierte a AgendaYa de "herramienta" a "activo imposible de abandonar".